

kb2-web 外部安全评估报告修复反馈

kb2-web 外部安全评估报告修复反馈

评估对象：kb2-web 政务知识库系统（FastAPI + SQLite + pgvector + DeepSeek） 反馈日期：2026-08-14 修复基准：GitHub main 20a4493 → e72778e（3 commits，全部已推送）

一句话结论

外部评估报告 43 项全部闭环：8 项真问题已修复（P0×2 / P1×4 / CC 复审 3 项 / P2×2，涉及 5 个文件 +41/-31），4 项报告误判已澄清（Swagger / CORS / 输入限制 / rerank 超时），其余项复核确认为已修复或低风险。修复经 Claude Code 三轮独立复审全部通过，单测 19 passed / 22 skipped，关键查询无回归。

修复闭环总表

优先级	问题	判定	修复内容	验证证据
P0	登录限速多进程失效	已修复	workers 降为 1（单机单 worker 计数回归设计值 5 次/60s/IP）+ X-Forwarded-For 优先（适配反代）	第 6 次登录返回 429
P0	C5 reparse 孤儿向量（hindsight 后端）	已修复	hindsight 分支先按 doc_id: tag 匹配内部 id 再 DELETE（复用 delete_document 模式，覆盖 pgvector +	无孤儿向量残留

优先级	问题	判定	修复内容	验证证据
P1	C1 category 过滤 doc_id 缺陷	复 已修	hindsight 双后端) 统一 _get_doc_key 提取 doc_id (tags 回退), 修复 isolated 文档漏过滤 + 定向分类查询误丢	分类过滤查询结果正确
P1	H3 编码 hack (报告 4 处, 实为 5 处)	复 已修	FastAPI 路由入口统一 _fix_encoding, 删除散落 latin-1 hack	中文/费用/标准号查询无回归
P1	S6 HTTP 安全头缺失	复 已修	中间件: X-Frame-Options DENY / X-Content-Type-Options nosniff / Referrer-Policy / CSP	curl -D 验证齐全 + CSP 浏览器实测无 JS 错误
P1	S7 /api/auth/me 缺失	复 已修	新增端点: 返回 username + role; 未知用户最小权限 viewer , admin 配置账号特判	admin→admin、非 User 表账号→viewer
P2	C3 RRF 内部 k 不一致	复 已修	rpf_merge 顶部 effective_k 双分支必定义; BM25 分支改用 effective_k (与 dense 同分母)	GB/T 12325 标准号查询 1034 字准确答案; 非标准号查询行为零变化
P2	H10 retrieval.py DB 连接泄漏	复 已修	5 处 SessionLocal 收 try/finally 兜底 (L464/L486/L574/L996/L1138, L257 原本正确)	代码走查 6/6 处全部有 close 路径 (CC 复核)

误判澄清 (报告结论不成立, 不采纳)

报告项	报告结论	实际判定
Swagger 关闭”未部署”	/docs 返回 200	误判: 200 是前端 SPA catch-all 返回的 index.html, API 文档实际已关闭 (docs_url=None)

报告项	报告结论	实际判定
CORS 反射漏洞	.env 未改	误判：代码为固定白名单 (allow_origins=settings.cors_origins) ，非通配非反射；部署 .env 仓库内不存在
输入限制“401 非 400”	未生效	误判：401 是全局 auth 先拦；带 token 测 501 字返回 400，已生效
LLM rerank 超时 120s	高危	误判：外层 asyncio.wait_for 30s 封顶并取消协程，内层 120s 不构成实际风险

过程性改进（可借鉴价值）

1. 评估基准对齐：报告基于 GitHub 代码，行号与本地服务状态可能漂移——先 git fetch 双向 diff 确认三方（报告 / CC(GitHub) / 本地验证）评估同一代码，再逐项裁决
2. 黑盒验证 $\neq$ 全路径正确：C3 内部 k 不一致、C5 hindsight 后端盲区、编码 hack 5 处（非 4）均由 CC 从源码读出——修复必须覆盖所有后端分支（pgvector + hindsight）
3. **CC** 复审闭环：P0+P1 修复后派 CC 独立复审 $\rightarrow$ 3 项跟进（/me 最小权限、XFF 限速、长度检查先于编码修复） $\rightarrow$ 全部修复后再提交。审计 43 项 $\rightarrow$ P0 $\times$ 2+P1 $\times$ 4+CC 3 项+P2 $\times$ 2 全闭环
4. **/me** 最小权限教训：默认 viewer 首次修复漏 admin 配置账号特判（配置账号不在 User 表） $\rightarrow$ 回归后补 username == settings.admin_username 分支

遗留项与路线图

项	说明	预估
P3 前端角色感知	/me 角色逻辑已就绪，前端 AppHeader/views 按 role 隐藏管理入口 (viewer)	0.5 人天
审计 v4	待 GA/T 496 + GDZW 0082 批量重解析完成后，基于新数据全量复核	1 人天
C 类低价值项决策	全库审计 C 类 $\sim$ 15 个低价值文档（重复/过期）决策清理	0.5 人天
DeepSeek 上游稳定性	间歇 httpx.ReadTimeout/400/502 为外部 API	外部依赖

项	说明	预估
	问题，已加超时兜底， 非本地缺陷	

附：commit 链

e72778e fix(retrieval): P2审计修复 – C3 RRF内部k收敛(BM25同用
effective_k)+DB连接泄漏5处finally兜底
6ba27ec fix(auth): CC审查3项 – /me最小权限viewer(admin配置账号特殊)
+XFF限速+编码修复先于长度检查
f4c0a8a fix(security): 审计报告P0+P1修复 – C5孤儿向量/登录限速单进程/C1
category过滤/编码hack清理/安全头//auth-me端点